SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.no	192411213	**Name of the Student**	Lakshmipathi Deepthi

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I Lakshmipathi Deepthi(192411213) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

L.Deepthi

ANSWERS

A2-Vulnerability Assessment Report

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each.

1. Malware

Malware is malicious software designed to damage systems, steal information, or gain unauthorised access. Common types include viruses, worms, Trojans, ransomware, and spyware.

- Example: Ransomware encrypts a company's files and demands payment to restore access.
- Preventive measure: Install updated antivirus software, apply security patches, and avoid downloading files from untrusted sources.

2. Phishing

Phishing is a cyberattack in which attackers use deceptive emails, links, messages, or websites to trick users into revealing passwords, banking details, or other sensitive information.

- Example: An employee receives a fake bank email asking them to enter their login credentials on a fraudulent website.
- Preventive measure: Conduct security awareness training, verify suspicious messages, and use email filtering and multi-factor authentication (MFA).

3. Denial of Service (DoS)

A DoS attack attempts to make a server or network unavailable by overwhelming it with excessive requests from a single source or system.

- Example: An attacker sends excessive requests to an online shopping website, preventing customers from accessing it.
- Preventive measure: Apply rate limiting, configure firewalls, and filter abnormal traffic.

4. Distributed Denial of Service (DDoS)

A DDoS attack uses multiple compromised devices, commonly called a botnet, to flood a target with traffic and disrupt its services.
- Example: A botnet sends a large volume of requests to a college website, making it unavailable to students.
- Preventive measure: Use a Content Delivery Network (CDN), DDoS protection services, and traffic-scrubbing solutions to filter malicious traffic.
Difference between DoS and DDoS:

DoS	**DDoS**
Usually originates from a single source.	Originates from multiple distributed devices.
Generally easier to identify and block.	More difficult to mitigate because traffic comes from many sources.
Usually involves a smaller number of traffic sources.	Can generate very large volumes of traffic.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures.

Definition

A Man-in-the-Middle (MitM) attack occurs when an attacker secretly intercepts communication between two parties and may read or modify the information exchanged without their knowledge.

Working of a MitM attack

1. The attacker positions themselves between two communicating parties.
2. The attacker intercepts communication between the victim and the intended destination.
3. If the communication is not adequately protected, the attacker may read sensitive information or modify transmitted data.
4. The attacker may use the captured information to steal credentials or impersonate a user.

Techniques used

1. ARP poisoning: The attacker sends forged ARP messages to associate their MAC address with another device's IP address, redirecting local network traffic.
2. Rogue Wi-Fi access point: The attacker creates a fake wireless hotspot that resembles a trusted network to intercept inadequately protected communications.
3. DNS spoofing: The attacker provides false DNS information to redirect users to a fraudulent website.
4. Session hijacking: The attacker steals or misuses a session token to impersonate an authenticated user.

Countermeasures

- HTTPS/TLS: Encrypts data exchanged between clients and servers.
- VPN: Protects network traffic through an encrypted tunnel.
- Certificate validation: Helps verify the identity of the intended server.
- HSTS: Enforces HTTPS connections for supported websites.
- Dynamic ARP Inspection (DAI): Helps detect and block invalid ARP messages on supported networks.

Conclusion: MitM attacks can compromise confidentiality and integrity. Encryption, proper certificate validation, and secure network configuration help reduce these risks.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented.

Difference between spoofing and sniffing

Spoofing is the act of forging identity or network information to impersonate a legitimate user, device, or service. Sniffing is the process of capturing and analysing network packets to observe communication.

Spoofing	Sniffing
Falsifies identity or address information.	Captures and examines network traffic.
May be used to impersonate systems or redirect traffic.	May be used to monitor communication or steal exposed data.
Example: IP address spoofing.	Example: Capturing packets using Wireshark.
Controlled through authentication and anti-spoofing measures.	Risks are reduced through encryption and network monitoring.

Types of spoofing

1. IP spoofing: An attacker forges the source IP address of packets to make them appear to originate from another system. For example, malicious traffic may carry a forged source address.
2. MAC spoofing: An attacker changes a device's MAC address to imitate another device on a local network.
3. Email spoofing: An attacker forges the sender address of an email to make it appear to come from a trusted organisation.
4. DNS spoofing: False DNS information redirects users to an unintended or malicious website.

Sniffing and its detection

Packet sniffing tools such as Wireshark and tcpdump capture and analyse network packets. Administrators use them legitimately to troubleshoot networks and investigate suspicious traffic, while attackers may misuse them to capture unencrypted information.
Sniffing can be difficult to detect because packet capture is often passive. However, suspicious network activity and unauthorised monitoring devices may

be identified through security monitoring and network audits.

Prevention measures

- Encryption: Use HTTPS/TLS and other secure protocols to protect data in transit.
- Switched networks: Use properly configured switches to limit unnecessary delivery of unicast traffic to other ports.
- Port security: Restrict unauthorised devices and MAC addresses on switch ports.
- Anti-spoofing filters: Apply ingress and egress filtering to reject packets with invalid source addresses.

Conclusion: Spoofing falsifies identity, whereas sniffing captures network traffic. Encryption, secure network configuration, and monitoring help protect against their misuse.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report.

Definition

A vulnerability assessment is a systematic process of identifying, analysing, prioritising, and reporting security weaknesses in computer systems, applications, and networks.

Steps in vulnerability assessment

1. Asset identification: Identify the systems, servers, applications, devices, and network resources that require assessment.
2. Vulnerability scanning: Use tools such as Nessus or OpenVAS to identify outdated software, known vulnerabilities, and insecure configurations.
3. Analysis and validation: Examine scan results, eliminate duplicates, and validate findings where possible.
4. Risk rating and prioritisation: Assess severity using CVSS scores and consider exploitability, exposure, and asset importance.
5. Reporting: Document findings, evidence, impacts, and recommended remediation actions.
6. Remediation and verification: Apply patches or configuration changes and perform follow-up scans to confirm that vulnerabilities have been addressed.

Contents of a good vulnerability assessment report

Section	Description
Executive summary	Provides an overview of the assessment and major risks.
Scope and methodology	Lists the assessed systems, assessment boundaries, tools, and methods used.
Vulnerability findings	Describes each identified vulnerability and the affected asset.
CVE and CVSS details	Includes applicable CVE identifiers and CVSS severity scores.
Evidence	Provides scan results, affected versions, configuration details, or other supporting evidence.
Risk and impact	Explains possible consequences, such as data theft or service disruption.
Remediation recommendations	Suggests patches, configuration changes, and other corrective actions.
Conclusion and follow-up	Summarises the overall security position and recommends reassessment.

Vulnerability assessment vs penetration testing

- Vulnerability assessment identifies and prioritises potential weaknesses across systems.
- Penetration testing attempts to exploit selected weaknesses within an authorised scope to demonstrate whether they can be used to compromise security.

Conclusion: A vulnerability assessment report helps organisations understand their security weaknesses and take corrective action according to risk and business priorities.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common

threat data sources and the techniques used to collect threat data.

Definition of OSINT

Open-Source Intelligence (OSINT) is the process of collecting, analysing, and interpreting information from publicly available sources to produce useful intelligence about potential threats.

Common threat data sources

1. Open-source data: Public security reports, vulnerability databases, security blogs, news websites, forums, social media, and code repositories.
2. Internal data: Firewall logs, endpoint alerts, authentication logs, incident reports, and network monitoring records.
3. Commercial data: Paid threat intelligence services that provide curated indicators, threat reports, and information about attacker infrastructure.
4. External community sources: Information shared by security researchers, industry groups, government agencies, and cybersecurity communities.
5. Honeypots: Monitored decoy systems that collect information about suspicious connections, attack techniques, and malicious activity.

OSINT sources and tools

- WHOIS: Provides domain registration information that can help investigate suspicious domains.
- Shodan: Helps identify internet-connected devices and potentially exposed network services.
- VirusTotal: Analyses files, URLs, domains, and IP addresses using multiple detection engines and intelligence sources.
- CVE/NVD databases: Provide information about publicly documented vulnerabilities and their associated risk details.

Techniques used to collect threat data

1. Passive collection: Gathering information from public websites, security reports, threat feeds, and published databases without directly probing the target.
2. Web scraping: Automatically collecting permitted information from web pages for analysis, subject to website terms and access restrictions.

3. DNS and domain lookups: Examining domain records, DNS resolution information, and related infrastructure to investigate suspicious activity.
4. Log analysis: Reviewing internal firewall, server, and endpoint logs to identify unusual behaviour.
5. Threat feed integration: Importing indicators from external sources into security monitoring tools for analysis and detection.

Legal and ethical considerations

- Collect only information that is lawfully accessible and relevant to the investigation.
- Respect privacy, data protection laws, website terms, and access restrictions.
- Avoid unauthorised access, intrusive scanning, or collecting unnecessary personal information.
- Verify information before using it to make security decisions.

Conclusion:

OSINT and other threat data sources help organisations identify emerging threats, investigate suspicious activity, and improve cybersecurity. Combining public intelligence with internal and commercial data provides a more complete view of risk.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs

and describe how threat feeds help organizations improve their defense.

Definition of IoCs

Indicators of Compromise (IoCs) are observable pieces of evidence that may indicate a computer system, network, or application has been compromised by malicious activity.

Types of IoCs

Type	Description	Examples
File-based IoCs	Indicators associated with suspicious or malicious files.	Known malicious file hash; suspicious executable file.
Network-based IoCs	Indicators observed in network traffic or connections.	Known malicious IP address; communication with a malicious domain.
Host-based IoCs	Indicators observed on an individual computer or server.	Unusual registry modification; unexpected suspicious process.
URL-based IoCs	Web addresses associated with malicious activity.	Phishing URL; URL used to distribute malware.

What is a threat intelligence feed?

A threat intelligence feed is a continuously updated source of information about known or suspected cyber threats, including malicious IP addresses, domains, URLs, file hashes, and attacker activity.
Threat feeds may be open-source or commercial. Common structured formats and sharing standards include STIX (Structured Threat Information Expression) and TAXII (Trusted Automated Exchange of Intelligence Information). STIX represents threat intelligence, while TAXII supports its exchange between systems.

How threat feeds improve organisational defence

1. Faster detection: Security tools can compare network traffic, files, and logs against known malicious indicators.
2. Automated blocking: Firewalls and other security systems can block confirmed malicious IP addresses, domains, or URLs when appropriate.
3. Incident investigation: Analysts can search for indicators to identify affected devices and determine the possible scope of an attack.
4. Threat hunting: Security teams can search historical logs for evidence of known attacker activity.
5. Improved response: Relevant intelligence helps security teams prioritise alerts and take timely containment measures.

Advantages and limitations

Advantages:

- Provides timely information about known threats.
- Supports automated detection and incident response.

Limitations:

- False positives can trigger unnecessary alerts or blocks.
- Stale indicators and limited context can reduce accuracy.

Threat feeds should be validated and combined with information about the organisation's own systems, business priorities, and current threat activity.

Conclusion:

IoCs help identify signs of compromise, while threat feeds distribute these indicators to security tools and analysts. Together, they support early detection, investigation, and faster incident response.